

ISO 27005 Methodology for Information Security Risk Management

ISO 27005 is an international standard that provides guidelines for information security risk management, supporting the general concepts specified in ISO 27001. It outlines a structured approach for identifying, assessing, and treating information security risks.

Key Components of the Risk Management Process (as per ISO 27005):

1. **Context Establishment:** Defines the guidelines for identifying risks, accountability for risk ownership, how risks affect confidentiality, integrity, and availability of information, and calculating risk effect and probability.
2. **Information Security Risk Assessment (ISRA):** This involves:
 - Creating a database of information assets.
 - Determining the risks and vulnerabilities each asset faces.
 - Assigning values to the effect and probability of occurrence.
 - Comparing vulnerabilities to predefined acceptability thresholds.
 - Determining which threats should be tackled first and in what order.
3. **Information Security Risk Treatment:** Unacceptable risks are addressed. Treatment options include:
 - **Avoid:** Completely remove the possibility of the risk.
 - **Modify:** Implement security measures to reduce the vulnerability.
 - **Assign/Transfer:** Transfer risk to a third party (e.g., insurance, outsourcing).
 - **Retain:** Accept the risk if it falls within established risk acceptance criteria.
4. **Information Security Risk Acceptance:** Organizations establish their own risk acceptance requirements based on strategies, priorities, targets, and shareholder interests.
5. **Information Security Risk Monitoring and Review:** Risks are dynamic and require active monitoring to detect shifts and maintain a complete picture. This includes monitoring new assets, changes in asset values, new internal/external risks, and information security incidents.
6. **Information Security Risk Communication:** Effective communication ensures that all stakeholders understand risk management decisions and rationale. Sharing ideas helps reach consensus on risk handling.